

CISM Domain 4A — Incident Management Readiness: Exam Essentials

Domain 4 (Incident Management) = 30% of the exam ≈ 45 of 150 questions — second largest. Part A covers the IR plan (4A1), BIA (4A2), BCP (4A3), DRP (4A4), incident classification (4A5), and training/testing/evaluation (4A6).

Incident Management vs Incident Response (4A1)

- **Incident Management (IM)** = the strategic program: planning, policies, governance, continuous improvement — “big picture.” **Incident Response (IR)** = immediate action when an incident is declared — “boots on the ground.” IR executes parts of IM.
- **Primary goal: minimize impact** on the organization. Specific goals in order: **protect human life and safety FIRST**, then minimize downtime, maintain CIA, prevent recurrence, comply, protect reputation.
- Risk management prevents; incident management responds. **Materialized risk = incident.** Goal: contain the incident so it never becomes a disaster.
- When a possible breach is reported: **FIRST validate the incident** (confirm it IS one) before any other action (exam answer).
- **Teams:** Emergency Action, Damage Assessment, Emergency Management (coordination/decisions), Relocation, Security/CSIRT. Define roles BEFORE an incident.
- Plan challenges: no management buy-in, misalignment with org change, team turnover, poor communication, **overly complex plans.**

Incident Handling Life Cycle (SANS — memorize the order)

1. **Preparation** — plans, policies, tools, training, management support
2. **Identification** — detect, VALIDATE, analyze, prioritize
3. **Containment** — limit scope/magnitude, preserve evidence
4. **Eradication** — remove the root cause
5. **Recovery** — restore systems to normal (meet RTO/RPO)
6. **Lessons Learned** — post-incident analysis, update plans

NIST SP 800-61 compresses this to: Preparation → Detection & Analysis → Containment/Eradication/Recovery → Post-Incident Activity. **Containment comes before root-cause analysis**; business continuity beats forensics unless the question is about legal proceedings.

Business Impact Analysis (4A2)

- **Three core goals: criticality prioritization, downtime estimation (MTD), resource requirements** — also the BIA’s essential outputs (exam answer: “downtime tolerance, resources and criticality”).
- Assess impacts across all of **C, I, and A**; tangible (financial) AND intangible (reputation).
- Use realistic scenarios, not just worst-case (worst-case-only inflates risk). Understand **loss escalation over time** — that’s what sets realistic RTO/RPO.
- BIA feeds everything: risk management, BCP, DRP. Flow: **BIA → (AIW, RTO, RPO, SDO, MTD) → BCP + DRP → test & maintain.**

Metric	Meaning
--------	---------

MTD	Maximum Tolerable Downtime — absolute longest the business survives disruption (determine FIRST)
AIW	Acceptable Interruption Window — max tolerable business process downtime
RTO	Recovery Time Objective — how QUICKLY systems must be restored
RPO	Recovery Point Objective — how much DATA LOSS is acceptable
SDO	Service Delivery Objective — minimum service level needed DURING recovery

Shorter RTO/RPO/AIW = more expensive recovery option (hot/mirror/DRaaS).

Business Continuity Plan (4A3)

- **BCP keeps the BUSINESS running**; IR handles the immediate incident; DR restores IT. RTO/RPO must be consistent across all three — recovery is only as fast as the slowest plan. Incident classification determines which plan activates.
- **Availability concepts**: SPOF (identify & eliminate), resilience, high availability (clustering, load balancing, failover), fault tolerance (RAID). Network continuity: redundancy, diverse routing, alternate routing, last-mile protection.
- **Insurance = risk TRANSFER, not elimination**. Understand exclusions, deductibles, prerequisites. Cyber insurance: know ransomware payout rules, third-party coverage, reporting requirements. Insurers mandate controls — compliance keeps coverage valid.
- **MOST important for disaster recovery success: detailed technical recovery plans maintained OFFSITE** (exam answer — staff may be unavailable; documentation must survive).

Disaster Recovery Plan (4A4)

DRP = restore **IT systems and data** after disaster; technical focus (BCP = business focus). DRP activates AFTER a disaster; BCP includes prevention and mitigation too.

ISACA DR phases:

1. Risk assessment + BIA
 2. Define response & recovery strategy
 3. Document DR/business recovery plans
 4. Train teams
 5. Update and test plans regularly
 6. Audit the plans
- **Critical site-selection factor: GEOGRAPHIC SEPARATION** — the recovery site must not be hit by the same disaster.

Site	Cost	Effort	Description
Cold	Low	High	Space, power, network only — move hardware in after disaster
Warm	Medium	Medium	Hardware pre-installed — load software and data to recover

Hot	High	Low	Live replica, immediate cutover — for mission-critical systems
Mirror	Highest	None	Identical ACTIVE site running concurrently
DRaaS	OpEx	Low	Cloud provider handles replication/recovery; geographic diversity
MAA/reciprocal	Lowest	—	Mutual agreement with another org — HIGH RISK, hard to enforce, AVOID

- **DRP document:** activation triggers, roles, contact lists, step-by-step procedures, resource inventory, communication strategy — **clear simple language, copies offsite.**
- **MOST important BCP/DRP consideration: alignment with RTOs** — recover the most critical systems first (exam answer).

Strategy	Know this
Full	Everything; simplest restore (1 set)
Incremental	Changes since LAST backup of any type; fast backup, slow restore (full + ALL incrementals)
Differential	Changes since last FULL; faster restore (full + LAST differential only)
Offsite speed	Recovery fastest → slowest: remote mirroring (exact replica) > remote journaling (continuous transaction logs) > electronic vaulting (batch transfers)

Incident Classification & Escalation (4A5)

- **Categorization = TYPE** (malware, outage — routes to the right team). **Classification = SEVERITY/PRIORITY** (impact + urgency — drives response speed, resources, escalation).
- **Escalation** defines when/how/to whom as severity rises or time passes: documented triggers, authority (who declares disaster), pre-listed notification recipients, secure channels. Step fails or time expires → escalate IMMEDIATELY.
- **Help/service desk = first line of contact** — train to spot security red flags vs routine IT issues (incl. social engineering) and escalate immediately per procedure.
- For incidents on critical application servers, notify the **information security manager FIRST** — they invoke escalation as needed (exam answer).

Training, Testing & Evaluation (4A6)

Five BC/DR test types, least → most disruptive:

1. **Read-through** — distribute and review the plan; checks familiarity
 2. **Walkthrough / tabletop** — moderated scenario discussion; tests understanding & communication
 3. **Simulation** — active test of specific components; may use some alternate resources
 4. **Parallel** — backup systems run alongside production at alternate site
 5. **Full interruption** — shut primary down, run from recovery site; the ultimate proof, most risk
- ISACA's three categories: paper tests → preparedness tests → full operational tests (in that order).

- Frequency: less disruptive tests more often; full interruption rarely (e.g., annually). Test internal teams AND external vendors/stakeholders.
- **Best confirmation BC/DR objectives were achieved: RTO was met during testing** (objective evidence — exam answer).
- Update plans on triggers: strategy shifts, new tech, M&A, regulation, site changes. Metrics: time to respond/resolve (tie to RTO), incidents resolved, trends. KPIs = activity vs targets; KGIs = strategic goals.

Quick Self-Check (from the handout)

1. SOC analyst reports possible breach — first action? → **Validate the incident**
2. Essential outputs of a BIA? → **Downtime tolerance, resources, criticality**
3. Most important for successful disaster recovery? → **Detailed recovery plans maintained offsite**
4. Most important BCP/DRP consideration? → **Alignment with RTOs**
5. Who is notified first for critical app server incidents? → **Information security manager**
6. Best confirmation BC/DR objectives achieved? → **RTO met during testing**

Last-Minute Memory Hooks

- Human life and safety always comes first
- Validate before you act; contain before you analyze root cause
- PICERL: Prepare, Identify, Contain, Eradicate, Recover, Lessons learned
- BIA answers: what's critical, how bad, how long, what's needed
- MTD first, then RTO/RPO; shorter objectives = pricier sites
- Categorization = type; classification = priority
- IR = incident, DR = technology, BC = business
- Plans offsite, geographically separate sites, avoid reciprocal agreements